

Zadatak 3 - Površina napada (Attack Surface)

Površina napada predstavlja skup svih ulaznih tačaka kroz koje korisnici i eksterni sistemi komuniciraju sa sistemom, a koje napadači mogu iskoristiti za izvođenje napada. Za multinacionalnu korporaciju poput MegaTravel-a, koja opslužuje više od sto miliona korisnika i operiše na tri kontinenta, površina napada je izuzetno široka i obuhvata digitalne, mrežne i fizičke vektore.

1. Identifikacija aktera

Pre mapiranja ulaznih tačaka, neophodno je identifikovati sve aktere koji komuniciraju sa sistemom, jer svaki akter podrazumeva određen skup ulaznih tačaka.

Krajnji korisnici (putnici) pristupaju sistemu putem veb i mobilnih aplikacija kroz javni internet. Pošto sistem ne može unapred da veruje u legitimnost njihovih zahteva, ovim akterima se dodeljuje najniži nivo poverenja.

Agenti u filijalama su zaposleni u predstavništvima širom sveta koji koriste interne CRM aplikacije za upravljanje rezervacijama i korisničkim nalogima. Imaju viši nivo poverenja od krajnjih korisnika, ali kompromitovani nalog agenta može otkriti lične podatke velikog broja klijenata.

Sistem administratori i DevOps inženjeri upravljaju infrastrukturom, CI/CD pajplajnama i procesom isporuke softvera. Imaju visok nivo poverenja i pristup kritičnim delovima sistema, što ih čini posebno vrednom metom za napadače.

Poslovni analitičari koriste analitičke i *business intelligence* platforme za praćenje poslovnih trendova i kampanja. Njihovi nalozi nude pristup osetljivim poslovnim podacima.

Od **eksternih** automatizovanih sistema, relevantni akteri su:

- procesori plaćanja koji komuniciraju putem API-ja i webhook mehanizama;
- GDS sistemi koji se koriste za sinhronizaciju dostupnosti letova;
- partneri za smeštaj, transport i iznajmljivanje vozila koji putem API integracija razmenjuju podatke o kapacitetima;
- servisi za mape i geolokaciju koji obezbeđuju podatke o destinacijama.

2. Ulazne tačke

Na osnovu identifikovanih aktera, moguće je mapirati konkretne ulazne tačke koje čine površinu napada MegaTravel sistema.

Javno dostupni interfejsi predstavljaju najizloženiji segment. REST i GraphQL API endpointi koje koriste mobilne i veb aplikacije dostupni su svima sa internet konekcijom i izloženi su napadima kao što su SQL injection, DDoS i Broken Object Level Authorization (BOLA) - napad u kome napadač pristupa tuđim rezervacijama jednostavnom izmenom identifikatora u zahtevu. Forme za

pretragu i unos podataka potencijalni su vektori za Cross-Site Scripting (XSS) napade, dok su portali za registraciju i autentifikaciju meta Brute Force i Credential Stuffing napada.

B2B i integracioni interfejsi obuhvataju webhook endpointe koje koriste procesori plaćanja za slanje potvrda transakcija - kompromitovani webhook može dovesti do finansijskih prevara ili lažnog knjiženja uplata. Outbound API veze ka partnerima za smeštaj, transport i iznajmljivanje vozila predstavljaju poseban rizik: ukoliko je sistem partnera kompromitovan, napadač može plasirati lažne ili manipulisane podatke nazad ka MegaTravel platformi, što je scenario poznat kao trovanje podataka ili Second-order SQL injection. Isti princip važi i za GDS integracije.

Interni i administrativni interfejsi su potencijalno najkritičnija kategorija. CRM portali koje koriste agenti u filijalama direktno izlažu lične podatke korisnika, a napadač koji kompromituje jedan nalog agenta može pristupiti informacijama velikog broja klijenata. SSH pristup serverima i Kubernetes dashboard omogućavaju potpunu administrativnu kontrolu nad infrastrukturom. CI/CD pajplajni su naročito osetljivi jer kompromitovani build proces može uvesti maliciozni kod direktno u produkcijsko okruženje bez vidljivog znaka upozorenja. VPN gateway je ulazna tačka za zaposlene koji rade na daljinu i meta je napada usmerenih na krađu kredencijala.

Email i SMS kanali, koji se primarno koriste za slanje potvrda rezervacija, mogu biti zloupotrebljeni za phishing kampanje usmerene ka korisnicima ili zaposlenima.

3. Zaključak

Analiza je pokazala da površina napada MegaTravel sistema nije uniformna. Najveća koncentracija rizika nalazi se na spojevima sa eksternim sistemima - partnerskim API-jima i GDS integracijama - gde se sistemu prezentuju podaci čiji integritet MegaTravel ne može direktno da verifikuje. Administrativni interfejsi i CI/CD infrastruktura predstavljaju drugu kritičnu tačku, jer njihova kompromitacija može imati posledice po celokupan sistem. Fizičko prisustvo u globalnoj mreži filijala uvodi i dimenziju fizičke bezbednosti koja mora biti uzeta u obzir prilikom modelovanja pretnji.

Izvori:

OWASP API Security Top 10 - <https://owasp.org/www-project-api-security/>

<https://phptravels.com/blog/the-importance-of-cybersecurity-in-the-tourism-industry>